



File No.: EXP202213437

RESOLUTION OF RECOURSE FOR RECONSIDERATION

Examined the recourse for reconsideration filed by CAIXABANK, S.A. (hereinafter, the appellant) against the resolution issued by the Director of the Spanish Agency for Data Protection dated December 12, 2024, and based on the following

FACTS

FIRST: On December 12, 2024, a resolution was issued by the Director of the Spanish Agency for Data Protection in file EXP202213437, by virtue of which CAIXABANK, S.A. was imposed the following penalties for the following infringements:

- ☐ From Article 5.1. f), GDPR, classified under Article 83.5 a) as very serious for the purposes of prescription in Article 72.1 a) of the LOPDGDD, a fine of 500,000 euros (five hundred thousand euros)
- ☐ From Article 25 of the GDPR, classified under Article 83.4 a) of the GDPR and classified as serious for the purposes of prescription in Article 73 d) of the LOPDGDD, a fine of 3,000,000 euros (three million euros).

Additionally, CAIXABANK, S.A. was ordered, pursuant to Article 58.2.d) of the GDPR, within three months from the enforceability of the resolution that is issued, to adopt the necessary measures to ensure that the processing of personal data it carries out complies with the provisions of the GDPR, specifically regarding the guarantees of confidentiality of the data being processed and the adoption of all types of technical and organizational measures that are appropriate.

In relation to the infringement of Article 25 of the GDPR, the measures consist of notifying, within nine months from when the resolution that concludes this sanctioning procedure becomes enforceable, the adoption of technical and organizational security measures by design and by default, that ensure that the online banking application of the entity being claimed protects personal data in general for all clients of the entity being claimed.

This resolution, which was notified to the appellant on December 13, 2024, was issued following the processing of the corresponding sanctioning procedure, in accordance with the provisions of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (LOPDGDD), and supplementary to Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), regarding the processing of sanctioning procedures.

SECOND: As proven facts of the aforementioned sanctioning procedure, PS/00477/2023, the following was recorded:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

PROVEN FACTS

FIRST:

Claimant 1, A.A.A., is the holder of three bank accounts at CAIXABANK, S.A., specifically as follows:

- ☐ ***REFERENCE.1.
- ☐ ***REFERENCE.2
- ☐ ***REFERENCE.3

In the first of the indicated accounts, claimant 2 is listed as a co-holder, and in the last two accounts, C.C.C., mother of claimant 1, is listed as an authorized person.

SECOND:

The details of the products associated with each account are as follows:

1. ***REFERENCE.1.

In this account, the holders are:

A.A.A. and B.B.B.

The following product is linked to this account:

***REFERENCE.4: Ownership of A.A.A.

Associated with this card contract is B.B.B. as the beneficiary and holder of three cards.

***REFERENCE.5: Ownership of B.B.B.

1. ***REFERENCE.2

In this account, A.A.A. is listed as the holder and C.C.C. and D.D.D. as recognized signatories.

For collection purposes, the following product is linked to this account:

***REFERENCE.6: Ownership of A.A.A. and where C.C.C. is listed as authorized.

1. ***REFERENCE.3

In this account, A.A.A. is listed as the holder and C.C.C. as the recognized signatory.

The following products are linked to this account:

***REFERENCE.7: Ownership of A.A.A. and with one associated card.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/31

***REFERENCE.8: Ownership of A.A.A. and with one associated card.

***REFERENCE.9: Ownership of A.A.A. and with two associated cards.

***REFERENCE.10: Ownership of A.A.A. and with one associated card.

***REFERENCE.11: Ownership of A.A.A. and with one associated card.

***REFERENCE.12: Ownership of A.A.A. and with two guarantors: D.D.D. and C.C.C.

***REFERENCE.13: Ownership of A.A.A.

***REFERENCE.14: Ownership of A.A.A.

***REFERENCE.15: Ownership of A.A.A.

***REFERENCE.16: Ownership of A.A.A.

THIRD:

On January 11, 2021, claimant 1 informed the defendant of an incident with reference number

***REFERENCE.17 regarding a specific operation in the accounts of which they are the holder.

According to the file, the incident is identified in the following terms: Their request for multi-signature has been correctly made but we have not been able to notify all signatories. Date January 11, 2021.

Time 16:59:39.

On January 27, 2021, claimant 1 communicated to the defendant an incident regarding their mother having access through her electronic banking application of Caixabank (Caixabank Now) to all financial information not only of herself but also of the account shared with claimant 2.

FOURTH:

On February 3, 2021, claimant 1 signed the CaixaBank Now contract (Contract No. (...))

***REFERENCE.18 related to account ***REFERENCE.2 and which allows for electronic operations related to it.

In section 2 of this contract - authorized users - the following is stated: Persons who can access your CaixaBankNow C.C.C., with ***NIF.1, User number ***REFERENCE.19 and Operational level.

According to page 9 of the aforementioned contract, section 1.2:

Additionally, you can appoint other persons to use your CaixaBankNow:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/31

> Authorized users: you authorize these individuals to access your CaixaBankNow at the Basic Access, Consultation, or Consultation and Preparation levels (see the next point), unless you indicate otherwise. This authorization becomes void when the time period for which you authorized it ends, or if you inform us that you no longer want the person to be authorized.

- > Customized users: you can decide the level of access you grant to these individuals, according to the following levels:
- > Basic: allows the user to submit documents to carry out various operations, such as direct debits, transfers, etc., which require the signature of the account holder or a user with full powers. The purpose is for the user to prepare the operations for you, as the account holder, to consent to later.
- > Consultation: allows the user to consult the contracted services as well as their specific operations.
- > Consultation and preparation: this is the sum of the two previous levels.
- > All permitted: the user can access all the services offered by CaixaBankNow.
- > Detailed: the user can have different levels of access, depending on the type of service: current account, investment fund, insurance, etc.

There is no definition regarding what should be understood as an authorized operational user.

In the document dated June 16, 2023, from the responding party, it is indicated that,

...no incidents have been detected by CaixaBank in the online banking operations of the Claimant (1) and the complaints regarding the functionalities of the online banking of the Claimant (1) are due to their own choices in the configuration of the views. (the underlining is ours)

FIFTH:

On 01/18/2021, Claimant 2 signs CaixaBankNOW contract no. (...) ***REFERENCE.20 in which they are listed as the primary account holder, dated 01/18/2021, associated with the account ending in ***REFERENCE.21, and in which no authorized user is listed.

SIXTH:

On 02/10/2021, Claimant 1 again informs the responding party that her mother can also see the products and transactions associated with the account ending in ***REFERENCE.21, an account in which she has not been registered as an authorized person.

SEVENTH:

On 02/11/2021, Claimant 1 informs the responding party that her mother could see the various products (including mortgage loans, insurance, and bank cards) associated with the accounts held by Claimant 1, including the one in which she is a co-holder along with Claimant 2.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/31

EIGHTH:

On February 17, 2021, Claimant 1 files a complaint with the responding party in which she highlights all the facts she has been reporting and requests the termination of what she qualifies as a transfer of data to third parties without authorization. Acknowledgment of receipt of this complaint is recorded on March 23, 2021.

In such document, she expresses her wishes regarding her mother's role as an authorized person in the current accounts of which she is the holder and co-holder, indicating that,

Therefore, from this moment, I revoke any "future contract" in the name of A.A.A. that according to my branch I have (I am still awaiting initial documentation) leaving only C.C.C. as authorized for the accounts ending in ***REFERENCE.23 and (...) as it has always been and has always been. (the underlining is ours).

NINTH:

On March 23, 2021, the responding party replies to Claimant 1 indicating that they are processing her complaint, to which they will respond as soon as possible and within a maximum period of one month.

TENTH:

Between February 19 and 21, 2021, Claimant 1 addresses the data protection officer of the responding party regarding the events that occurred.

In her email dated February 21, 2021, Claimant 1 explicitly states that:

1º I attach the complaint sent to my office no. 2409 where I explain everything that has been happening, and I believe it summarizes quite well everything that has been occurring to me. This

complaint was signed on 02-16-2021. Indicate, as you will read in the complaint, that the first incident where I noticed failures was on 01-11-2021 and from there it has only gotten worse. I attach my ID.
2º The individuals involved are B.B.B., C.C.C., and A.A.A.

3º Inability to carry out certain operations in all my accounts, due to the mandatory signature of the third party, in accounts where they are nothing. I believe this is explained in the complaint.

4º Transfer of data to a third party, although everything is explained in the complaint, I attach a video where this third party can see banking data that they should not see, and which they have NEVER viewed until the beginning of the year.

5º Indicate that my office has been aware of everything from the very first moment, the solutions and explanations (they are transmitted to me by my office, but they are indications given by La Caixa contact center or wherever). All this

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
6/31

Documentation, along with more photos and the rulings from the very beginning, is also in her hands. (the underlining is ours)

The only response to these communications is the reply from the data protection delegate to the email dated February 9, 2023 (two years after the complaint was filed with this entity and dated one day before the respondent answered on February 10, 2023, the request for information requested by the AEPD as a result of the filing of the complaint) in which the following is communicated:

We are contacting you regarding your complaint about the operation and visibility of products in your online banking contract (CaixaBank NOW). Given that in the last interactions we have had, we have not been able to configure to your satisfaction the operational and visibility powers of your products for the designated authorized persons, we would like to arrange an appointment with you at your office, which we would attend with the support of the technical departments of the Entity, with the aim of, following the indications and clarifications you provide, restoring and reconfiguring the authorizations for all your products. We hope that in this way we will be able to test with your intervention all the configurations you indicate, until the operation is to your complete satisfaction.

ELEVENTH:

On June 22, 2021, the claimant 1 filed a complaint with the Bank of Spain - Ref. File:

***REFERENCE.22.

TWELFTH:

On July 8, 2021, claimant 1 received an email from the lawyers of the respondent party with an attached proposal for an agreement, resulting from the complaint filed by claimant 1 with the Bank of Spain.

In it, it is indicated that,

As discussed over the phone, we are contacting you as lawyers for CaixaBank, regarding the complaint filed with the Bank of Spain with the reference number mentioned in the subject of the email. As we have discussed, we wish to convey CaixaBank's willingness to find an amicable solution to the situation you have raised, regarding the possibility of a third party being able to consult the positions of your products, despite not being authorized on them, but only on two sight accounts.

In this regard, and as we have indicated, it seems that there was a technical incident with your users and your mother, which should be resolved by providing new keys with correct access for you and your mother. In this sense, we will contact the office to initiate the procedures to verify that these keys are issued correctly before scheduling an appointment to deliver them. (the underlining is ours)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

Subsequently, on July 21, 2021, the lawyers of the respondent party sent an email to claimant 1 in which they state that this is a technical incident.

Thus, they indicate that,

I am writing to you again to inform you that we understand that the office staff and you have tested your new user keys for CaixaBankNow and that one of the problems you raised in your complaint has already been resolved. Now it only remains for your mother to perform the corresponding test to verify that with her user she can only access the products of yours in which she is listed as authorized. (the underlining is ours).

After that, on August 10, 2021, the lawyers of the respondent party sent an email to claimant 1 indicating that from then on, her mother can only consult the products for which she is authorized.

They point out that,

I am writing to you again to inform you that the necessary modifications have been made so that your mother can only consult through CaixaBankNow the products for which she is authorized by you.

On the same August 10, claimant 1 responds to the lawyers of the respondent party that the incident is still not resolved.

Finally, on August 13, 2021, through the email sent by the lawyers of the respondent party to claimant 1, it is shown how the incident, despite the previous assertions of the respondent party, was not resolved beforehand.

We apologize for the inconvenience. Unless there is an error, now indeed your mother can only access to consult the accounts for which she is authorized by you ((...)) and without access to card movements.

THIRTEENTH:

In response to the complaint filed with the Bank of Spain, and in order to argue that the claims of the claimant party were being satisfied, CaixaBank on July 21, 2021 stated the following: Given these statements, CaixaBank has proceeded to carry out the necessary verifications (...) that affect the digital banking users of the claimant and her mother as authorized.

FOURTEENTH:

The Bank of Spain sent to claimant 1, on July 26, 2021, a document indicating that a letter from CAIXABANK, S.A. had been received in this Department of Conduct of Entities, which communicates, in relation to the complaint filed on June 22, 2021, that they have proceeded to rectify the situation that was the subject of disagreement, having been notified to her by the entity itself, therefore we consider that her complaint has been resolved.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/31

having been satisfied in accordance with the provisions of Article 14 of Order ECC/2502/2012, of November 16, which regulates the procedure for filing complaints with the complaint services of the Bank of Spain, the National Securities Market Commission, and the Directorate General of Insurance and Pension Funds. It is indicated that as of this date, the complaint is being archived.

Claimant 1 submits allegations to the Bank of Spain, dated July 26, 2021, stating that they oppose the archiving, expressly indicating that the issue has not been resolved.

They state that,

Since January, and through all known channels (the only one who cared was my manager, and even he did not receive a response), I have tried to resolve things amicably, but I was NEVER given a solution or even a response. A formal complaint was filed on February 17, to which there was NEVER a solution or response (until the call on July 8), when they are obliged to respond within a MONTH. Let it be clear that the current situation we find ourselves in is solely and exclusively due to CaixaBank and their lack of responses from the beginning. Because of this, I feel belittled as a customer, as there has only been a response following the complaint to the BDE.

On the other hand, the current situation regarding the problem of this complaint remains the same, and I will obviously not stop anything that is unresolved. Furthermore, they have only contacted me when

there are more people involved here. (the underlining is ours).

FIFTEENTH:

On August 19, 2021, the lawyers of the claimant party sent a letter to the Bank of Spain regarding the complaint filed by claimant 1 with that entity (since after the allegations of claimant 1, the complaint filed by them was not archived).

They indicate that,

SOLE.- CaixaBank has proceeded to make the necessary adjustments to its control marks (replacing the “apoderada” with the “autorizada”), which is the source of the administrative error suffered, thereby automatically updating and correcting the viewing powers that the mother of the claimant has over her products, thanks to which it is currently noted that through the digital banking service via the internet CaixaBankNow, the mother of the claimant can only make inquiries about the products for which she is authorized, which are currently the current accounts (...).

...In this regard, we justify the adjustments made in this regard, both concerning the accounts and the limitation of card movements:

...this entity requests that the present file be archived, considering the entity as having complied and requesting that the doctrine established by this Department regarding administrative errors be applied, and consequently, declare the non-existence of actions contrary to good banking practices. (the underlining is ours).

SIXTEENTH:

Claimant 2 submits a complaint to the defendant party on October 4, 2021, reporting the same facts as claimant 1.

They indicate that,

Data transfer by Caixa to a third party without authorization.

All cards linked to account ***REFERENCE.21 are viewed by C.C.C.. This has been happening for more than 9 months, without you providing a solution to the problem. This lady has nothing to do with my accounts and even less with my cards. My right is being violated by transferring data for months and months.

For all this, I request that you order the necessary instructions to rectify this immediately. (the underlining is ours).

The defendant party responds on October 27, indicating that it is not possible to admit the facts for processing since it is being substantiated before the Bank of Spain.

SEVENTEENTH:

By Report dated December 23, 2021, the Bank of Spain resolves the complaint filed by claimant 1, indicating that,

In this case, between the date (February 17) when the prior complaint was received by the entity and the date when the entity's lawyers contacted the claimant in writing - via email - (July 8), months elapsed. There is no record of a response from the customer service to the complaint other than the acknowledgment of receipt. And although we do not have the document or the data of the authorization that the claimant granted to her mother, in any case, the claimant since February 2021 expressed her disagreement with the information that her mother had access to or was provided, authorized by her, and reiterated time and again – providing demonstrative videos – that the issue remained unresolved at that date. (the underlining is ours).

Furthermore, the report indicates that after the submission of allegations by the defendant party 1 regarding the archiving of the complaint filed with the Bank of Spain,

The banking entity submitted a new letter of allegations dated August 19, 2021, in which it again requests the archiving of the file for compliance and states that it has made the necessary adjustments to its control marks (replacing the “apoderada” with the “autorizada”),

10/31

source of the administrative error suffered, thereby automatically updating and correcting the viewing powers of the mother of the claimant. It states that on that date, the mother of the claimant could make inquiries through the CaixaBankNow digital banking service only about the products for which she is authorized: the current accounts number ... ***REFERENCE.23 and ...(...):

The claimant submitted a written statement on September 2, 2021, to oppose once again the

admission and filing of the case, stating that indeed on August 8 and 13, a lawyer informed her that everything was arranged, but that was not the case, and her mother could see the credit cards as well as all her mortgage data, life insurance, etc. She claims that, although the documentation provided by CAIXABANK indicates that everything is resolved, as of that date (09/02/2021) it is false and provides demonstrative videos. She clarifies that the documentation provided by CAIXABANK consists of screenshots from their computers, and from the beginning, her manager confirmed that everything was fine, and although they saw that on the screen, it was not true.

...The entity, in its two written statements of allegations, acknowledges the incident or error and communicates that it has been resolved. As supporting documentation for its allegations, it only provides the email sent to the claimant on July 8, 2021...The claimant, however, in her various writings, the last one dated September 2, 2021, indicates that the problem remained unresolved and provides demonstrative videos. Additionally, she complains about the lack of response from the entity to her complaint, which she first submitted at the bank office on February 17, 2021, and the customer service acknowledged receipt on March 23, 2021.

...At this point, we must point out that the failure of the entities to fulfill their obligation to address and resolve complaints and claims submitted by their clients in a timely manner reveals a deficient performance in the functioning of customer service and a neglect towards the user of the financial service, which could constitute a breach of transparency regulations (the emphasis is ours).

THIRD: The appellant submitted on January 13, 2025, before this Spanish Agency for Data Protection, a request for reconsideration, fundamentally based on these three aspects:

- The sanctioning resolution must be annulled for violating the principle of legality that governs the sanctioning power. The access to the shared account by the representative of the co-holder was consented to by B.B.B.: the shared account is subject to the regime of solidarity. There is no deficiency in the design of the online banking application.
- The sanctioning resolution must be annulled for violating the principle of culpability that governs the exercise of the sanctioning power. CaixaBank acted based on a coherent interpretation of the norm in accordance with the civil code.
- The sanction provided in the sanctioning resolution must be reduced. The imposed sanctions violate the principle of "non bis in idem" and do not adhere to the principle of proportionality.

LEGAL GROUNDS

I

Competence

The Presidency of the Spanish Agency for Data Protection is competent to resolve this appeal, in accordance with the provisions of Article 123 of the LPACAP and Article 48.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter, LOPDGGDD).

II

Allegations presented

The appellant bases her appeal, first of all, on the understanding that the sanctioning resolution must be annulled for violating the principle of legality that governs the sanctioning power. In her opinion, the access to the shared account by the representative of the co-holder was consented to by B.B.B. because the shared account is subject to the regime of solidarity. Based on that same argument, she states that there is no deficiency in the design of the online banking application. In this regard, the appellant argues her assertion by indicating that the basis on which the Sanctioning Resolution tries to sustain the commission of the indicated infringements is the alleged lack of consent from B.B.B. for A.A.A. to access the information of the Shared Account.

However, in her opinion, the sanctioning resolution ignores two elements of considerable importance: The Shared Account is subject to the regime of solidarity and C.C.C. was duly authorized to access the Shared Account.

She points out that the Shared Account is solidary, so that B.B.B. at the time of signing the Shared Account Contract consented to A.A.A. accessing the information of the account through CaixaBank. Now and, therefore, consented that such access could be made either by A.A.A. on her own or through a third party that A.A.A. authorized for that purpose (in this case C.C.C.).

In her opinion, the above evidences that the design of online banking is correct, as it precisely allows

co-holders of solidarity accounts (who have previously authorized the contract to be subject to the regime of solidarity) to empower representatives through the CaixaBank Now system so that they can view those accounts in the terms in which they have been expressly authorized.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
12/31

In this regard, the appellant states that the sanctioning resolution is based on an erroneous premise, confusing the figure of an attorney for a bank account with that of an authorized user in digital banking. According to the Sanctioning Resolution, since C.C.C. was only listed as the attorney for the two accounts whose sole holder was A.A.A., C.C.C. could only access the information of those two accounts, disregarding the authorization granted to C.C.C. through the CaixaBank Now system to access the information of the Shared Account. The appellant believes this reasoning is incorrect, as it is not necessary to be an attorney for a specific account (and therefore hold powers that could even include closing the account) to access information related to that account through the digital banking platform if authorized by the holder of the CaixaBank Now contract, a circumstance that was evidenced during the processing of the referenced procedure.

Furthermore, the appellant questions the assertion in the contested resolution that, in a case such as the one presented, the regime of solidarity or the powers of attorney provided for in civil law does not apply based on the principle of normative specialty, and that in this case, data protection regulations should prevail. In the appellant's view, this reasoning is incorrect for the following reasons: The principle of specialty requires that the special law be applied preferentially over the general law when a factual situation aligns more closely with the fact regulated in the special law. Conversely, the general law will apply to all matters not covered by the special law.

The regime of solidarity and powers of attorney is not provided for in the GDPR, and therefore, its analysis must be subject to civil law (which is the only regulation governing these matters). This is evident when referring to the Guide to the Right of Access from the EDPB, which explicitly states that civil law issues related to powers of attorney are not regulated in the GDPR, but rather in national legislation (in our case, the Civil Code). This circumstance, which is of significant relevance for resolving the present procedure, has been ignored in the Sanctioning Resolution. In particular, the aforementioned Guide to the Right of Access establishes the following:

“In this regard, national legislations that regulate representation (for example, notarial powers), [...] must be taken into account, as the GDPR does not regulate this issue.

In accordance with the principle of accountability, as well as the other principles of data protection, data controllers must be able to demonstrate the existence of the relevant authorization to [...] receive the requested information, unless national legislation differs (for example, if national legislation contains specific rules regarding the reliability of data controllers).”

To reinforce its argument, the appellant reiterates the judgment of the National Court already mentioned during the processing of the sanctioning procedure to conclude that, just as in the case adjudicated then, the AEPD must analyze whether, on one hand, A.A.A. could exercise her rights individually (considering the solidarity nature of the Shared Account) and, on the other hand, whether C.C.C.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
13/31

was or was not authorized to access the information of the Shared Account (considering the authorization granted in its favor through the CaixaBank Now system).

Thus, the AEPD must analyze whether there was a violation of data protection regulations based on the applicable regime to the legal relationship between the parties, a circumstance that continues to be ignored in the AEPD's approach (which continues to overlook the joint nature of the Shared Account,

as well as the scope of the authorization granted through the CaixaBank Now empowerment system). In this regard, and in accordance with the arguments put forth by the appellant, this analysis should necessarily lead the AEPD to conclude that C.C.C. could indeed access the Shared Account, taking into account the joint nature of the Account and the authorization granted in its favor through the CaixaBank Now system.

To this end, it is understood that the AEPD should have taken into account the joint nature of the Shared Account, as well as the fact that the CaixaBank Now system allows users to configure the level of access for representatives in a granular manner (without in any case being configured as a blanket authorization).

The appellant concludes by reiterating that, in its opinion, access was consented to, precisely, due to the joint nature of the Shared Account and the scope of the empowerment granted through CaixaBank Now.

For all these reasons, it considers that the contested resolution is contrary to law as it alters, beyond its competence, the legal regime of a contract validly entered into to derive consequences inappropriate to the civil legal regime applicable to that contract.

To these arguments, it adds a series of considerations regarding the practical consequences that would arise from applying the approach followed by the sanctioning resolution. For example, it refers to the situation that could arise regarding a representative of a co-holder of a joint account who could dispose of the funds, but to whom, in application of what is stated by the contested resolution, access to view the accounts would be denied for not having prior authorization from the co-holders. In its opinion, the situation would be nonsensical as it would allow the representative to dispose of the funds without the express authorization of the other co-holders, but, on the other hand, would not allow them to know the balance of the account in question.

Furthermore, in the appellant's view, the approach of the contested resolution would lead to a violation of the right of access of the authorized third party in relation to joint accounts, contravening the provisions of Article 12 of the LOPDGDD, which states that the exercise of the rights recognized in the GDPR may be exercised directly or through a legal or voluntary representative.

The appellant continues by rejecting that the statements made by it during the processing of the procedure before the Bank of Spain imply an acknowledgment of its responsibility. In this regard, it points out that the classification of the claimed facts—viewing personal data—as a technical incident does not imply an acknowledgment of responsibility, much less in matters of

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/31

data protection. It insists that the viewing of the information that was the subject of the complaint is not an error, but rather the normal functioning of the digital platform and is in accordance with the viewing permissions granted at each moment. Furthermore, it qualifies the classification of the facts in the procedure followed before the Bank of Spain as irrelevant for determining its liability in this procedure, as it insists that it can only be held responsible for actions that constitute an infringement.

The appellant insists on the autonomy of the will of the co-holder of the bank account, C.C.C., and that the viewing of the data related to her corresponded with the permissions that were granted at each moment. It confirms that the design of digital banking allows third parties authorized by the co-holders of joint accounts to view the content of those accounts if they have been duly authorized. In its opinion, even in the hypothetical and denied case of considering that the authorization granted was revoked, this situation would have affected a specific case and could not serve as a basis to question the design of online banking, which, resulting from the regime of solidarity and the regime of empowerment, allows authorized third parties to view accounts subject to the regime of solidarity if they have been duly authorized.

Finally, it states that, in its opinion, the infringement of Article 25 of the GDPR would be time-barred. It understands that the facts would have been committed at the time the complaint was filed with the AEPD - January 27, 2021 - and considers that by the time the agreement to initiate the sanctioning

procedure was issued - January 18, 2024 - the infringements had already expired since more than two years had passed from the moment the alleged infringement occurred (in accordance with the statute of limitations provided in Article 73 of the LOPDGDD).

Secondly, the appellant argues that the sanctioning resolution must be annulled as the subjective element of culpability required for the exercise of the sanctioning power is not present. This is because it considers that CaixaBank acted based on a coherent interpretation of the norm in accordance with the civil code.

In its opinion, understanding otherwise would distort the dynamics of solidarity relationships (which allow for the independent exercise of rights in the manner deemed appropriate), as well as distort empowerment, which allows for the independent exercise of rights through a third party (who acts as a sort of alter ego in legal transactions).

On the other hand, it considers that its conduct cannot be deemed culpable, as it sought to collaborate at all times with the complainant. It refers to the conversations held with her both by the Customer Service and by its Data Protection Officer, who, it claims, offered to arrange an in-person meeting so that she could configure the scope of the authorization granted. However, A.A.A. declined CaixaBank's proposal, as stated in the letter of June 15 submitted to the AEPD.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/31

Thirdly and finally, the appellant states that the imposed sanctions violate the principle of “non bis in idem” and do not adhere to the principle of proportionality.

The appellant believes that the regime of concurrent offenses provided for in Article 29.5 of Law 40/2015 should have been applied, in accordance with the jurisprudential criterion maintained by the National Court. This is because, hypothetically, the fact of having incurred in the infringement of Article 25 of the GDPR (design error) would have led to a violation of the principle of confidentiality.

Therefore, the alleged commission of one of the infringements has led to the other.

On the other hand, it questions that the sanctioning resolution does not contain justification regarding the calculation of the amount of the imposed sanctions, which it considers manifestly contrary to the principle of proportionality, especially considering the circumstances of the case: there is only one claim related to the viewing permissions, meaning it is not a generalized case but rather completely specific, and the appellant attempted to collaborate with the claimant. Therefore, it believes that the provisions of Article 83.2 b) cannot be applied as an aggravating factor since there was no intent or negligence in the infringement, according to the interpretation that the National Court has made of this circumstance.

III

Response to the allegations presented

Firstly, it should be noted that the arguments on which the presented appeal is based coincide with the allegations already made by the appellant during the processing of the sanctioning procedure. All of them were duly analyzed and dismissed in the contested resolution.

Firstly, regarding the infringement of the principle of legality, it is necessary to begin by pointing out what is indicated in the proven facts of the contested resolution, specifically the fourth:

FOURTH:

On 02/03/2021, Claimant 1 signed the CaixaBank Now contract (Contract No. (...)

***REFERENCE.18) related to account ***REFERENCE.2, which allows for electronic operations related to it.

In section 2 of this contract - authorized users - the following appears:

Persons who can access your CaixaBankNow C.C.C., with ***NIF.1, User number ***REFERENCE.19 and Operational level.

According to page 9 of the aforementioned contract, section 1.2:

Additionally, you can appoint other persons to use your CaixaBankNow:

C/ Jorge Juan, 6

16/31

> Authorized users: you authorize these persons to access your CaixaBankNow at the Basic Access, Consultation, or Consultation and Preparation levels (see the next point), unless you inform us otherwise.

This authorization becomes void when the time period for which you authorized it ends, or if you notify us that you no longer wish for the person to be authorized.

> Customized users: you can decide the degree of access you grant to these persons, according to the following levels:

> Basic: allows the user to submit documents to carry out various operations, such as direct debits, transfers, etc., which require the signature of the account holder or a user with full powers. The purpose is for the user to prepare the operations for you, as the holder, to consent to them later.

> Consultation: allows the user to consult the contracted services as well as their specific operations.

> Consultation and preparation: is the sum of the two previous levels.

> All permitted: the user can access all services offered by CaixaBankNow.

> Detailed: the user can have different levels of access, depending on the type of service: current account, investment fund, insurance, etc.

No definition is provided regarding what should be understood as an operational level authorized user. Therefore, the contract to which the appellant refers so many times and in which, as it repeatedly indicates, the claimant's choice regarding the viewing operations of the account shared with B.B.B. is recorded, refers to an account - the one ending in ***REFERENCE.23 - which does not correspond to the account shared by the claimants - ending in ***REFERENCE.21. Furthermore, in the contract made through CaixaBank Now, C.C.C. is granted the status of operational level authorized user. Thus, as has been demonstrated by the documentation contained in the file - and as reflected in the aforementioned - Proven Fact - the contract referred to by the appellant does not pertain to the shared joint account of the claimants - and the main subject of the claim presented before the AEPD - does not contain at any time a definition of what should be understood as an operational level authorized user, and much less can it be inferred from it that C.C.C. had the status of attorney for A.A.A. (the claimant) as the appellant repeatedly attempts to indicate. This lack of definition regarding the scope of the granted authorization is relevant not only to undermine that we are dealing with an authorization with the scope that the appellant intends to give it, but also to question whether such authorization, as the appellant claims, can be equivalent to a power of attorney.

It should also be noted that, since 10/02/2021, the claimant has been repeatedly communicating that the movements and products associated with the account ending in ***REFERENCE.21 could be viewed by her mother who, contrary to what the appellant has stated, had never been registered as authorized for that account and, therefore, could not be considered

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

17/31

as the attorney in the terms and with the scope that the appellant intends to give to this concept, in relation to the present case. These circumstances are clearly evidenced by what is established in Proven Fact eight, which reflects the communication addressed to the appellant. Therefore, from this moment on, I revoke all "future contracts" in the name of A.A.A. that according to my branch I have (I still expect initial documentation), leaving only C.C.C. as authorized for the accounts ending in ***REFERENCE.23 and (...) as it has always been and has always been. (the underlining is ours). It is indisputable, therefore, that C.C.C. was never authorized by A.A.A. in the account shared by the claimants, the one ending in ***REFERENCE.21, and regarding which the appellant insists on considering that the viewing permissions are in accordance with the solidarity regime that would apply

to said account.

In short, C.C.C. was never authorized—and even less so empowered, concepts that the appellant uses interchangeably—regarding the account shared by the claimants before this AEPD, A.A.A. and B.B.B. For this reason, contrary arguments in this regard cannot be accepted, including those regarding the alleged violation of Article 12 of the LOPDGDD, which provides that the rights recognized in the GDPR to the data subject may be exercised through representation.

It is worth recalling what was stated in the contested resolution (FD III) in the following sense: In this regard, for its interest, let us remember that the Bank of Spain, in the aforementioned report of December 23, 2021, regarding the figure of the authorized person in a bank account, states the following (the underlining is ours): Authorized persons are individuals who, with the express consent of the holders, can generally dispose of the existing balance in the account. They are not authorized to modify the conditions of the contract, nor to cancel the account, nor to make withdrawals against the account after the death of the holder. The status of authorized person is obtained through the express authorization of the holder or holders of the account and usually in writing, being a banking practice that both the signatures of the holders and the authorized persons are collected at that moment.

In this regard, we note that the authorization, as indicated by the Bank of Spain itself, refers to a power of disposition regarding the funds deposited in the bank account. A different issue must be understood regarding the viewing of the movements related to all products associated with it; a circumstance that has occurred in the case at hand, as reflected in the terms of the complaint.

On the other hand, the Bank of Spain states that the status of authorized person is obtained by (...). Applied to the case at hand, and considering the account ending in ***REFERENCE.24 as a shared account between both claimants, the status of authorized person for a third party would require the express authorization of both co-holders. Since the respondent claims that, once claimant 1 designates her mother as authorized, she acquires that status regarding all accounts held (including the one shared with claimant 2), it can only be understood that this practice would be contrary to what is stated by the Bank of Spain itself.

Therefore, attempting to apply the solidarity regime governing the account shared by the claimants to any other account held by one of the co-holders, extending the authorizations granted by them, indeed implies an interpretation contrary to the very rules governing the solidarity regime.

On the other hand, the intended contrary argument regarding the application of the principle of specialty must also be rebutted, in accordance with what has already been argued in the sanctioning resolution: In this sense, it should be indicated that if the respondent were raising a possible collision between the Civil Code and the current regulations on personal data protection, it should be indicated that in these cases the principle of specialty applies, according to which the norm with a direct and specific regulation of the matter in question prevails over any other.

Jurisprudential interpretation denies the supplementary nature of the general law in matters directly regulated by the special law. The principle of specialty resolves the problem of the competition of laws or the apparent conflict between them through the preferential and priority application of the special norm.

And all this without prejudice to the fact that the respondent itself, in the document sent on August 19, 2021, to the Bank of Spain regarding the complaint filed by claimant 1 before that entity, indicates that, SOLE.- CaixaBank has proceeded to make the necessary adjustments to its control marks (substituting "attorney" for "authorized"), source of the administrative error suffered... (the underlining is ours).

Thus, the case at hand seeks to discern whether access to the data of the current account, as well as to card No. ***REFERENCE.25, associated with account ***REFERENCE.1, held by both claimant 1 and claimant 2, constitutes or does not constitute a violation of personal data protection regulations.

As the issue to be addressed concerns the protection of personal data, in accordance with the

principle of specialty, the GDPR and the LOPDGDD apply preferentially due to their specialty in the matter.

19/31

Therefore, it is absolutely essential, in addition to what the Bank of Spain indicates in its report of December 23, 2021, to obtain the consent of both claimants in order to access the data of card No. ***REFERENCE.25, associated with account ***REFERENCE.1. This is so because said account is owned by both claimants, not just claimant 1, which means that both have the right to have their personal data processed lawfully, which necessarily implies that consent has been granted by, in this case, both account holders, all in accordance with Article 6.1 a) of the GDPR.

(...)

In this regard, it should be noted that allowing access to a third party, in this case to the mother of claimant 1, to the movements of the account and the products associated with it, where she is not listed as an authorized person, constitutes a breach of personal data, categorized as a breach of confidentiality. According to the GT29, a "Breach of confidentiality" occurs when there is an unauthorized or accidental disclosure of personal data, or access to the same.

(...)

On the other hand, the appellant insists that the level of access corresponded to the choice—and therefore, to the consent granted—by the claimant herself. Notwithstanding that it has been considered proven that such a circumstance was not the case regarding the account shared by the claimants (the one terminated in ***REFERENCE.21), the contested resolution argues as follows:

Furthermore, even if that consent had been considered valid, from the moment the claimant expresses, actively and passively, continuously (to the point of filing complaints with the entity, with its data protection officer, with the Bank of Spain, and with the AEPD) her opposition to access by the person allegedly authorized by her to the account shared with claimant 2 and the products associated with it, for the purposes of data protection, and even in the civil sphere, it can be understood that she revoked the consent. Therefore, from that moment on, that processing of personal data would lack legal coverage, and the respondent party should have resolved the issue raised by claimant 1 immediately. On the contrary, the clear will of claimant 1, expressed, as we say, repeatedly, was not attended to by the respondent party in an attitude that cannot be described as anything other than highly negligent. As a case in point, let us remember that the communications from claimant 1 dated February 19 and 21, 2021, addressed to the Data Protection Officer of the respondent party were answered on February 9, 2023, two years later and only one day before the respondent answered on February 10, 2023, the information request made by the AEPD, once a complaint had been filed with this Authority.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/31

These circumstances would demonstrate an undue attention by the responding party to the repeated statements by the claiming party of their will contrary to access to their personal information that was occurring.

It is appropriate to bring up at this point the contrary intention to highlight their willingness to cooperate with the claimant, denying that their attitude can be considered negligent. From the established facts, it follows, contrary to the arguments made by the appellant, that this willingness to cooperate and to provide a response to what was raised by the claimant was not such from the moment the claiming party communicated to the now appellant on 10/02/2021 the facts, and that, despite communicating with their Data Protection Delegate a few days later, they did not receive a response until two years later and after the filing of a complaint before this AEPD.

On the other hand, the appellant again raises that, in their opinion, the conclusions reached by the National Court in its judgment of October 3, 2024, would be applicable. In this regard, the contested resolution already indicated the following:

The responding party brings up the judgment issued by the National Court, Administrative Litigation

Chamber, Section 1, Judgment of October 3, 2024, Rec. 990/2022, in which, as well indicated in the written allegations, a case is presented regarding the opening of a bank account by a third party without having the power of representation that would enable them to do so. As the responding party rightly points out, the National Court concludes that the contract for the opening of the bank account formalized exceeded the limits of the notarial power granted to the third party. However, the responding party fails to point out that what is precisely determined in this judgment is the necessity to prove consent for the processing of personal data of an interested party—in the case at hand, the daughter in whose name a bank account is opened based on a notarial power granted to her father, exceeding the limits of the same—and, in the case of the present sanctioning procedure, allowing the visualization of the account shared by claimants 1 and 2 by the mother of the first, without the due authorization—and that, in the present case, such consent, informed, free, and unequivocal as required by data protection regulations, has not occurred.

It is interesting to bring up part of the argument contained in the aforementioned judgment to again reiterate that the responding party did not act with due diligence since, just as in the case at hand (...) There the banking entity did not act with the diligence that as such entity is required since it included in the current account a person who was not sufficiently represented in the power employed by Carlos Francisco for its opening, and their inclusion obeyed solely to that generic position of co-owner or member of a community of goods.

In the facts from which the present sanctioning procedure arises and in light of the persistent statements made by the claimants, it is not

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/31

acted with due diligence to terminate the mother of claimant 1's access to the shared account and the associated products, as the defendant undoubtedly desired.

It is again interesting to recall the literal wording of the judicial ruling brought up by the defendant, which reminds us that the scope of competence of the Data Protection Agency regarding civil matters—such as contracting cases—is limited. In this regard, the National Court recalls that: As the parties acknowledge, this issue has been resolved by the chamber, and we refer to the judgment of May 8, 2014 (appeal no. 1/142/2013):

"...we will first analyze the invoked incompetence of the Spanish Data Protection Agency, since in the case at hand the existence of a contract is raised, which is a civil matter, not a personal data protection issue. This is a matter that [...] has been repeatedly dismissed by the Chamber in the following manner. It is the responsibility of the Spanish Data Protection Agency, pursuant to art. 37.a) of the LOPD, to ensure compliance with data protection legislation and to control its application, as well as to exercise the sanctioning power as provided in Title VII of the aforementioned Law (art. 37.g).

Therefore, it has the competence to suppress behaviors that affect the realm of data protection, among which are violations of the principles of consent and data quality as appreciated by the contested administrative resolution and established in arts. 6.1 and 6.3 of the LOPD. And if these principles require that the data of a person processed by a third party be done with their consent and be truthful and accurate, the Spanish Data Protection Agency, solely for the purpose of determining whether or not a violation of the aforementioned principles has occurred, can make an assessment regarding whether the consent for the processing of the affected person's data in relation to certain services is covered by the contracting of such services and regarding the accuracy and truthfulness of a certain piece of data, such as the existence of a debt reported to a solvency file.

In the case at hand, this Data Protection Agency is precisely doing that, ensuring compliance with data protection regulations and, in this case, considers that the conduct for which the defendant is responsible has not respected the principles contained therein, which has resulted in a violation of the right to data protection of the claimants.

Furthermore, it should be noted that the legal system is not composed of isolated normative sections and that data protection regulations are applicable in a transversal manner, and that the alleged

application of civil legislation claimed by the defendant does not outright exclude the application of the GDPR.

It is worth recalling at this point, even at the risk of being repetitive, that the claimant never granted any type of authorization to her mother, C.C.C., in relation to the account.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/31

shared with B.B.B. Attempting to extend the authorization granted in relation to other accounts held by the claimant—different from the one ending in ***REFERENCIA.21, which corresponds to the shared account—constitutes, regarding the facts to be judged by this AEPD, a violation of the right to data protection of the co-holders of the shared account.

Again, the appellant argues that the procedure followed before the Bank of Spain cannot be considered as a “recognition” of its responsibility. In this regard, in addition to recalling that this AEPD has limited itself to objectively assessing the statements made during this procedure, especially concerning the qualification that the appellant attributed to the events that occurred—qualified as a technical incident—in the contested resolution it was already indicated as follows:

On the other hand, the entity being complained about, in its allegations to the proposed resolution, qualifies as “irrelevant” the considerations made by the Bank of Spain in the report following the complaint presented to that Authority by the claimants.

In this sense, it should be noted that the Bank of Spain is a supervisory and control authority, recognized in Law 13/1994, of June 1, on the Autonomy of the Bank of Spain, in whose article 7.6 establishes among its functions the following:

“The Bank of Spain must supervise, in accordance with current regulations, the solvency, performance, and compliance with specific regulations of credit institutions.”

It is within the framework of its functions that the claimants approached the Bank of Spain, on different dates, as stated in the proven facts, and that, as a result of the procedure carried out by that Supervisory Authority, in its report of December 2021, it makes the statements reflected in the seventeenth proven fact, among which the following stand out:

(...) in any case, the claimant since February 2021 expressed to the entity her disagreement with the information that her mother had or to which she accessed, authorized by her, and reiterated time and again—providing demonstrative videos—that the incident remained unresolved at that date. (the underlining is ours).

(...)

The banking entity submitted a new written statement of allegations dated August 19, 2021, in which it again requests the filing of the case due to compliance and states that it has made the necessary adjustments to its control marks (replacing “authorized representative” with “authorized”), which was the source of the administrative error suffered, thereby automatically updating and correcting the viewing powers of the claimant's mother. (...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/31

...The entity, in its two written submissions, acknowledges the incident or error and communicates that it has been resolved. As documentation attached to its submissions, it only provides the email sent to the claimant on July 8, 2021... The claimant, however, in her various writings, the last one dated September 2, 2021, indicates that the problem remained unresolved and provides demonstrative videos. Furthermore, she complains about the lack of response from the entity to her claim, which she first presented at the bank office on February 17, 2021, and the customer service acknowledged receipt on March 23, 2021.

...At this point, we must point out that the failure of the entities to address and resolve within the

stipulated time the complaints and claims presented by their clients, which reveals a deficient performance in the functioning of the customer service and a neglect towards the user of the financial service, could constitute a breach of transparency regulations (the underlining is ours).

These excerpts, in addition to reflecting the insistence and forcefulness with which the claimant expressed her desire for her mother to stop viewing information for which she did not wish to authorize, also indicate how the responding party acted regarding what was stated—repeatedly and forcefully, we insist—by the claimant, qualifying the situation as an incident or error.

One cannot help but question, in light of what is now alleged by the respondent, that if what was raised by claimant 1 was classified within the framework of the investigation conducted by the Bank of Spain as an “incident or error,” it now seeks to question the relevance of such allegations to argue its lack of culpability in the conduct subject to the present sanctioning procedure. Thus, this inconsistency regarding the very qualification of the facts (before the banking supervisory authority, an incident or error, and before this AEPD, as an operation derived from the authorization granted by claimant 1) only serves to demonstrate, in our opinion, the responsibility of the respondent in the events that occurred.

And this, of course, without prejudice to the fact that the respondent itself had consistently considered that the claimed facts were the result of an incident. A position that, as has been evidenced, was only modified when this AEPD initiated sanctioning proceedings for violation of data protection regulations. On the other hand, the appellant insists on considering the infringement of Article 25 of the GDPR as time-barred. Such an argument was duly rebutted in the sanctioning resolution (page 70) in the following terms:

The responding entity also points out in its submissions to the proposed resolution that the infringements of Articles 32 and 25 of the GDPR—which correspond to the alleged absence of adequate measures and the alleged deficiencies in design—have expired due to the events occurring in 2021.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
24/31

In response to such a statement, the AEPD must indicate that both violations are not time-barred, as the entity being claimed against has not taken measures to prevent the commission of both violations, and thus, their non-compliance continues to occur. Therefore, the obligation to adopt appropriate technical and organizational security measures to ensure an adequate level of security relative to the risk arising from the processing of personal data (Article 32 GDPR) and to establish procedures that take privacy by default and by design into account arises with the entry into force of the GDPR in May 2018, and its non-compliance remains until measures are adopted in this regard. The events of 2021 merely demonstrate the level of compliance with these obligations. It should be noted that a permanent violation is considered to exist, as stated by the TS in its ruling of November 20, 2007, (Rec. 170/2003), regarding “those unlawful behaviors that persist over time and are not exhausted by a single act, determining the maintenance of the unlawful situation at the will of the author, such as the ongoing development of activities without the necessary authorizations and other similar cases.”

The second of the arguments on which the appeal for reconsideration is based—the absence of the subjective element of culpability in the facts—was also addressed and dismissed in the contested resolution. All of this in the following terms:

Regarding the allegations related to the absence of culpability, the entity being claimed against insists on the consent given by the claimant, co-holder of the shared account, which allowed the authorized person (her mother) to view all the products.

The AEPD must emphasize again that it is absolutely essential, as indicated by the Bank of Spain in its report of December 23, 2021, to have the consent of both claimants to access the shared account and the products associated with it.

This is so because this account is owned by both claimants, not just claimant 1, which means that both

have the right for their personal data to be processed lawfully, which necessarily implies that consent has been granted by both in this case.

In this regard, the AEPD must emphasize the absence of information about the conditions of the authorized user at the operational level and the deficiencies of consent, as the mere fact that someone consents does not imply that the processing is lawful if such processing is contrary to the regulations on personal data protection. Furthermore, it must be taken into account that, in the event that it could be considered that initial consent was granted, it has been revoked clearly and insistently, as observed from the various statements made by claimant 1 to the entity being claimed against over a period of almost two years.

The appellant also bases the absence of culpability on the collaborative conduct directed towards the claimant. In addition to what has already been noted in paragraphs.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

25/31

prior to this resolution - the excessive amount of time that elapsed between the communications made by the claimant regarding the visualization with which she was dissatisfied and the response provided by the appellant - it should be noted that the intended collaboration referred to by the appellant, besides being delayed in time, occurs after the maintenance of a situation - infringing the data protection regulations - that has been sustained over time and constitutes a clear violation of the right to data protection of the affected parties.

It is worth recalling on this point that the Bank of Spain itself concluded in its report the following:

In this case, between the date (February 17) when the prior complaint was received by the entity and the date when the entity's lawyers contacted the claimant in writing - via email - (July 8), several months elapsed. There is no record of a response from the customer service to the complaint other than an acknowledgment of receipt. And although we do not have the document or the data of the authorization that the claimant granted to her mother, in any case, the claimant since February 2021 has expressed to the entity her disagreement with the information that her mother had or to which she accessed, authorized by her, and reiterated time and again - providing demonstrative videos - that the incident remained unresolved as of that date.

(underlining is ours).

The claimant finally argues that the imposed sanction should be reduced, that they violate the principle of non bis in idem and that they do not adhere to the principle of culpability. All of these issues have already been addressed in the contested resolution, in the terms outlined below:

The respondent also alleges the existence of non bis in idem and the medial concurrence provided for in Article 29.5 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector, which limits the imposition of a single sanction in cases of committing infringements that necessarily derive from others. This is based on the understanding that the alleged commission of both infringements, under Article 5.1 f) and Article 32 of the GDPR, stem from a single fact.

In response to this argument, we must point out that Article 29 of the LRJSP does not apply to the sanctioning regime imposed by the GDPR, given that the GDPR itself regulates the principle of proportionality.

The GDPR is a European regulation directly applicable in the Member States, which contains a new, complete, and comprehensive system aimed at ensuring the protection of personal data uniformly throughout the European Union, which would not be achieved if each supervisory authority applied its national provisions in a manner that could be contrary to that harmonizing principle. And this also relates to the sanctioning regime established in the GDPR, whose provisions must be understood, interpreted, and integrated in a complete and integral manner, thus preserving its ultimate purpose, which is the effective and real guarantee of the fundamental right to the Protection of Personal Data.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

In fact, a specific example of the absence of gaps in the GDPR system is Article 83 of the GDPR, which determines the circumstances that may operate as aggravating or mitigating factors regarding an infringement (Art. 83.2 of the GDPR) or specifies the existing rule concerning a possible concurrent infringement (Art. 83.3 of the GDPR). Unlike Art. 29.5 of Law 40/2015, it does not consider that only the sanction corresponding to the most serious infringement committed should be imposed; rather, in the case of infringement of several provisions of the GDPR, "the total amount of the fine shall not exceed the amount provided for the most serious infringements." (That is, all infringements are penalized, but the total amount cannot exceed that provided in the GDPR for the most serious infringements.)

Article 63.2 of the LOPDGDD enshrines not only the supplementary nature (which would serve to fill gaps, which do not exist, as we have seen) but the subsidiary nature (which is not supplementary) of the general regulations of administrative procedures concerning the rules governing the procedures of the AEPD in the field of data protection.

Article 63.2 of the LOPDGDD states:

2. The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, insofar as they do not contradict them, in a subsidiary manner, by the general rules on administrative procedures.

The Spanish legislator has thus opted for the principle of subsidiarity, not of supplementarity, of the general rules of administrative procedure in relation to the specific rules of the GDPR and LOPDGDD. This relationship between supplementarity and subsidiarity must be understood in light of the ruling of the Audiencia Nacional of October 23, 2001 (Rec. 390/1999), which recalled that "the recourse to subsidiarity is a formula of normative collaboration for cases of concurrence of norms, that is, for cases in which two or more of them are applicable to the same factual situation, so that the subsidiary yields in favor of the primary one that, in its case, complements," unlike supplementarity, which aims to fill a gap "in such a way that when a particular situation is not subject to regulation by the initially applicable norm, recourse to supplementarity is made, always provided that such an operation does not, for other circumstances, conflict with the legal order."

In the present case, the primary norm would be the GDPR, which expressly regulates in its Art. 83.3 the possible existence of more than one infringement of the GDPR in the same processing operations or related operations (express regulation of a possible concurrent infringement), with the regulation of concurrent infringement provided for in Art. 29.5 of Law 40/2015 not being applicable precisely due to its subsidiary nature.

Article 83.3 of the GDPR states:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3. If a controller or a processor intentionally or negligently breaches various provisions of this Regulation for the same processing operations or related operations, the total amount of the administrative fine shall not exceed the amount provided for the most serious infringements. Consequently, it is not possible to apply the subsidiary regulation that contains a different regulation from the main regulation.

In addition to the above, we must add that the GDPR does not allow for the development or specification of its provisions by the legislators of the Member States, except for what the European legislator has specifically provided, delimiting it very precisely (for example, the provision of Article 83.7 of the GDPR). The LOPDGDD only develops or specifies certain aspects of the GDPR to the extent that it allows and with the scope that it permits.

This is so because the aim intended by the European legislator is to establish a uniform system throughout the European Union that guarantees the rights and freedoms of natural persons, corrects

behaviors contrary to the GDPR, promotes compliance, and enables the free movement of these data. In this regard, we cite, among others, recitals 2 and 13 of the GDPR.

Fines must be effective, proportionate, and dissuasive for achieving the purpose intended by the GDPR.

For this system to function with all its guarantees, it is necessary for several elements to be deployed in an integral and complete manner.

The application of rules external to the GDPR regarding the determination of fines in each of the Member States by applying their national law, whether due to aggravating or mitigating circumstances not provided for in the GDPR - or in the LOPDGDD in the Spanish case as permitted by the GDPR itself - or due to the application of a medial contest with a consequence different from that provided for in the GDPR, would undermine the effectiveness of the system, losing its meaning, its teleological purpose, the will of the legislator, resulting in fines imposed for different infringements ceasing to be effective, proportionate, and dissuasive, and in any case, the will to provide uniformity to the system throughout the European Union would be lost. In this way, the interested parties would also be deprived of the effective guarantee of their rights and freedoms, weakening the uniform application of the GDPR. The mechanisms for protecting the rights and freedoms of citizens would be diminished, which would be contrary to the spirit of the GDPR.

The GDPR is endowed with its own principle of proportionality that must be applied in its strict terms. Just as the AEPD is not applying the aggravating and mitigating factors set out in Article 29 of the LRJSP, since the GDPR establishes its own, therefore, there is no legal gap nor subsidiary application of the same, nor is there room for the application of the intended regulation of the medial contest for identical reasons.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
28/31

Finally, the entity being challenged makes a series of allegations related to the lack of proportionality of the imposed sanction.

First, according to the general conditions for calculating administrative fines provided in Article 83, paragraphs 5 a) - concerning the infringement of Article 5.1 f) of the GDPR - and 4 a) regarding infringements of Articles 32 and 25 of the GDPR, the administrative fines contemplated in this case are at the lower end of the possible sanctions. Therefore, compliance is given to the provisions of Article 83.1 of the GDPR: "Each supervisory authority shall ensure that the imposition of administrative fines under this Article for the infringements of this Regulation referred to in paragraphs 4, 5 and 6 is, in each individual case, effective, proportionate and dissuasive."

On the other hand, the challenged party also claims that the proposed sanction is not properly justified because "it should have indicated the amount of the proposed sanction without such aggravating factors, as well as the impact of each of them on it."

Article 83.2 of the GDPR states that "administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure for those provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:" (the underlining is ours). This means that the assessment of the sanction as a whole must consider all and each of the circumstances present in the specific case and that are provided for in the aforementioned provision. In this same line, the jurisprudence pronounces itself when referring to the principle of proportionality, a principle "fundamental that underlies and governs the process of scaling sanctions and implies, in legal terms, 'its adequacy to the seriousness of the constitutive fact of the infringement' as provided in Article 29.3 of Law 40/2015, on the Legal Regime of the Public Sector, given that every sanction must be determined in accordance with the severity of the infringement committed and according to a criterion of proportionality in relation to the circumstances of the fact." (Supreme Court rulings of December 3, 2008 (rec. 6602/2004) and April 12, 2012 (rec. 5149/2009) and National Court ruling of May 5, 2021 (rec. 1437/2020), among others).

Thus, the ruling of the Third Chamber of the Supreme Court, dated May 27, 2003 (rec. 3725/1999), indicates that “Proportionality, specifically belonging to the field of sanctions, constitutes one of the principles that govern in Administrative Sanctioning Law, and represents a control instrument for the exercise of the sanctioning power by the Administration within, even, the margins that, in principle, the applicable norm indicates for such exercise. It certainly implies a concept that is difficult to determine a priori, but which tends to adjust the sanction, by establishing its specific scaling within the indicated possible margins, to the severity of the constitutive fact of the infringement, both in its aspect of unlawfulness and of...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
29/31

the culpability, weighing in its entirety the objective and subjective circumstances that make up the sanctionable factual presumption (...)

We can also cite for this purpose the Judgment of the Supreme Court 713/2019, of May 29 (rec. 1857/2018): “We will begin by noting that the proportionality of sanctions implies that they are tempered to the particular severity of the act in conjunction with the subjective (referring to the offender) and objective (referring to the typical act) circumstances, given that in the field of administrative sanctioning law in general and in the area of the securities market in particular, there are no dosimetry criteria similar to those set forth in Article 66 of the Penal Code and that the modifying circumstances differ from those specific to the criminal sphere. Let us remember that the automatic application, without any nuance, of the guiding principles of criminal law to the administrative sanctioning procedure is not permissible (S.TS 6-10-2003 Rec.772/1998).”

Therefore, the Guidelines 04/2022 of the European Data Protection Committee on the calculation of administrative fines under the GDPR, in its version of May 12, 2022, submitted for public consultation, indicate that “As for the evaluation of these elements, increases or decreases in a fine cannot be determined in advance through tables or percentages. It is reiterated that the actual quantification of the fine will depend on all the elements collected during the investigation and other considerations related also to the previous experiences of the control authority regarding fines.”

In short, since in the present sanctioning procedure the circumstances that were taken into account for the provisional quantification of the sanction as a whole were duly indicated and explained, it is properly justified.

Regarding the fact that only one complaint has been filed—an argument that seems to suggest that the respondent considers the impact of the infringement to be limited—it is necessary to bring to attention Judgment No. 1792/2024, of the Third Section of the Contentious-Administrative Chamber of the Supreme Court, issued on November 11, 2024, in which the following is stated:

The Spanish Agency for Data Protection, in the initiation, processing, and resolution of a sanctioning procedure, may address factual and legal issues connected or related to the facts and arguments contained in the complaint that gives rise to the procedure. And, more specifically, in the course of a sanctioning procedure initiated as a result of one or more complaints regarding personal data protection, when it is noted that the specific infringements reported have a common origin in a document or instrument of general scope that defines the entity's policy regarding data protection, the AEPD may, and indeed must, make that same document, which houses the privacy policy of the responsible entity, the subject of the sanctioning procedure, in order to examine it, detect its possible shortcomings or deficiencies, and adopt, consequently, the measures that are necessary within the framework of the sanctioning procedure; (...)

In this sense, the Supreme Court considers that the powers of the Data Protection Agency extend to examining the actions that, in general, may be carried out by an entity subject to data protection regulations and that are contrary to it, regardless of the number of complaints filed that have allowed the AEPD to become aware of such circumstances. >>

In short, the arguments raised in the appeal submitted must be dismissed.

Conclusion

Consequently, in the present appeal for reconsideration, the appellant has not provided new facts or legal arguments that would allow for a reconsideration of the validity of the contested resolution. In view of the cited provisions and others of general application, the Presidency of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DISMISS the appeal for reconsideration filed by CAIXABANK, S.A. against the resolution of this Spanish Agency for Data Protection issued on December 12, 2024, in file EXP202213437.

SECOND: TO NOTIFY this resolution to CAIXABANK, S.A.

THIRD: To warn the sanctioned party that the imposed sanction must be made effective once this resolution is notified, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, within the voluntary payment period indicated in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by depositing it in the restricted account No. ES00 0000 0000 0000 0000 0000, opened in the name of the Spanish Agency for Data Protection at CAIXABANK, S.A., or otherwise, it will be collected in the executive period. If the date of notification falls between the 1st and the 15th of each month, inclusive, the deadline for voluntary payment will be until the 20th of the following month or the next business day, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

31/31

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions established in Article 123 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), interested parties may file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within a period of two months starting from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

Finally, it is noted that in accordance with the provisions of Article 90.3 a) LPACAP, the final resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Agency's Electronic Registry [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned LPACAP. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

180-020125

Olga Pérez Sanjuán

The Deputy Director General of Data Inspection, in accordance with Article 48.2 LOPDGDD, due to vacancy in the position of Presidency and Deputy

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es